DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

INFORME DE SEGURIDAD Y CALIDAD EN EL DESARROLLO DE SOFTWARE

Plan de pruebas — Sistema de exámenes médicos Cuidarte+

ISY1102 – Seguridad y calidad en el desarrollo de software

Sección 001V

Integrantes

Paola Narr
Scarlet Jara

Docente:Juan Azocar
Carrera: Ingeniería en Informática

Fecha: 17/09/2026

Contenido

1. Introducción 3
2. Criterios de calidad, seguridad y cumplimiento normativo 4
3. Plan de pruebas 5
   3.1 Estrategia de pruebas 5
   3.2 Tipos de prueba 6
   3.3 Criterios de aceptación 7
   3.4 Herramientas utilizadas 7
   3.5 Cronograma de ejecución 9
4. Diseño de casos de prueba 10
5. Conclusión 14
6. Referencias 15

1. Introducción

El presente informe describe el plan de pruebas diseñado para el sistema Cuidarte+, una plataforma web multicapa (Frontend en React, Backend en Node.js/Express y base de datos PostgreSQL) orientada a centros de salud, cuyo propósito es la gestión de pacientes, exámenes médicos y documentos clínicos, conforme a lo establecido en el documento de Especificación de Requerimientos de Software (ERS) del proyecto.

Dado que Cuidarte+ administra información clínica y datos personales sensibles de pacientes, resulta indispensable diseñar un plan de pruebas que no solo valide el correcto funcionamiento de las funcionalidades del sistema (autenticación, registro de usuarios, gestión de pacientes y exámenes, visualización de documentos y auditoría), sino que también verifique el cumplimiento de los requisitos no funcionales de seguridad, rendimiento, usabilidad, disponibilidad y compatibilidad, así como la normativa legal aplicable en Chile en materia de protección de datos personales y de datos de salud.

El propósito de este plan es asegurar que el sistema cumpla con los estándares de calidad exigidos antes del paso a producción, minimizando riesgos de seguridad, errores funcionales y problemas de accesibilidad, especialmente considerando que una parte importante de los usuarios finales corresponde a adultos mayores.

Este documento se estructura en los siguientes apartados:

2. Criterios de calidad, seguridad y cumplimiento normativo;
3. Plan de pruebas, que incluye la estrategia, los tipos de prueba, los criterios de aceptación transversales y las herramientas y recursos necesarios; y
4. El diseño detallado de los casos de prueba representativos para los distintos tipos de requerimientos definidos en el ERS.

2. Criterios de calidad, seguridad y cumplimiento normativo

A continuación, se establecen los estándares que debe cumplir Cuidarte+, en concordancia con el giro del negocio (salud) y con los requerimientos funcionales y no funcionales definidos en el ERS del proyecto.

Calidad (usabilidad, rendimiento, estabilidad, confiabilidad y mantenibilidad):

- Usabilidad y accesibilidad (NFR-USAB): interfaces con tipografía legible, contraste adecuado, controles de tamaño apropiado para pantallas táctiles y navegación por teclado, considerando especialmente a usuarios adultos mayores.
- Rendimiento (NFR-PERF): operaciones CRUD simples con tiempo de respuesta inferior a 300 ms, carga de la página principal en menos de 2 segundos en conexión móvil promedio y soporte de 200 usuarios concurrentes por defecto.
- Disponibilidad y mantenimiento (NFR-DIS): disponibilidad objetivo de 99,5% mensual, ventanas de mantenimiento planificadas y migraciones de datos seguras.
- Compatibilidad (NFR-COMPAT): soporte de navegadores modernos (últimas dos versiones de Chrome, Firefox, Safari y Edge) y diseño responsivo para dispositivos móviles y tablets.
- Mantenibilidad: documentación de endpoints mediante Swagger y cobertura de pruebas automatizadas sobre los endpoints críticos del backend.

Seguridad (protección de datos, control de acceso, manejo de errores e integridad de la información):

- Uso obligatorio de TLS en todas las comunicaciones cliente-servidor-base de datos (NFR-SEG-1).
- Hashing seguro de contraseñas mediante bcrypt (NFR-SEG-2) y política de contraseñas de al menos 12 caracteres con mayúsculas, minúsculas, números y caracteres especiales.
- Encriptación de datos sensibles en reposo (NFR-SEG-3) y control de acceso basado en roles (Administrador, Médico, Paciente) en el backend (NFR-SEG-4).
- Protección contra vulnerabilidades OWASP: CSRF, XSS e inyección SQL, mediante validación y saneamiento de entradas en todos los endpoints (NFR-SEG-5).
- Gestión segura de logs, sin exposición de datos sensibles, y registro de auditoría de toda acción crítica sobre pacientes, exámenes, usuarios y documentos (RF-5, NFR-SEG-6).

- Políticas de respaldo (backup) y recuperación ante desastres definidas y probadas periódicamente (NFR-SEG-7).
- Autenticación mediante tokens JWT de corta vigencia, con soporte de refresh token y revocación en el cierre de sesión (NFR-SEG-9).

Normativas (estándares técnicos, leyes y políticas internas):

- Ley N.º 19.628 sobre Protección de la Vida Privada, que regula el tratamiento de datos personales en Chile, con especial atención a los datos de salud del paciente, considerados datos sensibles (NFR-SEG-8).
- Ley N.º 20.584 que regula los derechos y deberes de las personas en su atención de salud, en lo relativo a la confidencialidad de la ficha clínica y de los exámenes médicos.
- Buenas prácticas de seguridad alineadas al estándar OWASP Top 10 y a lineamientos de referencia de ISO/IEC 27001 para la gestión de la seguridad de la información.
- Reglas de negocio definidas en el ERS: RB-1 (el paciente solo tiene permisos de lectura sobre su propia información), RB-2 (el administrador tiene acceso completo a las operaciones CRUD) y RB-3 (el médico puede visualizar la información clínica de cualquier paciente registrado).

3. Plan de pruebas

3.1 Estrategia de pruebas

Se aplicará una estrategia de pruebas mixta, combinando pruebas manuales exploratorias (especialmente para usabilidad y accesibilidad) con pruebas automatizadas para los aspectos funcionales, de seguridad y de rendimiento, con el fin de maximizar la cobertura dentro del tiempo disponible.

Etapas del proceso:

- Diseño de casos de prueba a partir del ERS y de los criterios de aceptación definidos.
- Preparación del ambiente QA y de los datos de prueba (usuarios, pacientes, exámenes y documentos de prueba).
- Ejecución de pruebas funcionales, de seguridad, de rendimiento y de usabilidad.
- Registro de defectos, re-ejecución (retesting) y regresión de los casos afectados.
- Cierre del ciclo de pruebas y elaboración del informe de resultados.

Herramientas que se podrían utilizar: Postman/Newman y Swagger para pruebas funcionales de la API REST; Jest y Supertest para pruebas automatizadas del backend; OWASP ZAP para pruebas de seguridad; k6 o JMeter para pruebas de carga y rendimiento; y Lighthouse para métricas de rendimiento y accesibilidad del frontend.

Priorización de pruebas: se priorizan los requerimientos críticos de autenticación y control de acceso (RF-1, NFR-SEG), por su impacto directo sobre la confidencialidad de datos clínicos; en segundo lugar, las operaciones CRUD sobre pacientes y exámenes (RF-2, RF-3, RF-4); y finalmente los requisitos no funcionales de rendimiento, usabilidad y compatibilidad.

Criterios de entrada: ERS aprobado y disponible; ambiente QA desplegado y estable; datos de prueba cargados; build del sistema disponible para pruebas.

Criterios de salida: 100% de los casos de prueba críticos ejecutados y aprobados; ausencia de vulnerabilidades de severidad crítica o alta sin resolver; defectos bloqueantes cerrados; métricas de rendimiento dentro de los umbrales definidos en el NFR-PERF.

3.2 Tipos de prueba

- Pruebas funcionales: validan el correcto comportamiento de RF-1 (autenticación y sesión), RF-2 (registro y gestión de usuarios/pacientes), RF-3 (gestión de exámenes médicos), RF-4 (visualización y descarga de documentos) y RF-5 (auditoría).
- Pruebas no funcionales: evalúan rendimiento, usabilidad, disponibilidad y compatibilidad, conforme a lo definido en la sección 3.3 del ERS.
- Pruebas de seguridad: verifican control de acceso por rol, resistencia a inyección SQL, XSS y CSRF, correcto hashing de contraseñas y uso obligatorio de TLS.
- Pruebas de integración: validan la comunicación correcta entre el frontend (React), el backend (Express) y la base de datos (PostgreSQL), incluyendo el almacenamiento y referencia de documentos en Storage interno.
- Pruebas de usabilidad: evalúan la accesibilidad y facilidad de uso de la plataforma, con foco en adultos mayores, conforme al criterio de aceptación de NFR-USAB.
- Pruebas de rendimiento: miden tiempos de respuesta de operaciones CRUD y comportamiento del sistema bajo carga concurrente (NFR-PERF).

3.3 Criterios de aceptación

A nivel transversal, un caso de prueba se considera aprobado o aceptado cuando se cumplen las siguientes condiciones:

- Funcional: el requerimiento se comporta exactamente como fue especificado en el ERS, sin errores ni comportamientos inesperados en los flujos principales y alternativos.
- No funcional: se cumplen los umbrales cuantitativos definidos (tiempos de respuesta, disponibilidad, compatibilidad de navegadores) y los criterios cualitativos de usabilidad y accesibilidad.
- Seguridad: no existen vulnerabilidades explotables de severidad crítica o alta; los mecanismos de control de acceso, cifrado y validación de entradas funcionan correctamente en el 100% de los intentos evaluados.
- Reglas de negocio: se respetan estrictamente las reglas RB-1, RB-2 y RB-3 según el rol del usuario autenticado.
- Auditoría: toda acción crítica (creación, edición, eliminación, subida o descarga de documentos) queda correctamente registrada en el módulo de auditoría.

3.4 Herramientas utilizadas

Recursos humanos (roles):

- Líder de pruebas (QA Lead): planifica, coordina y valida la ejecución del plan de pruebas.
- Analista de pruebas / Tester: diseña y ejecuta los casos de prueba funcionales y no funcionales.
- Analista de seguridad: ejecuta las pruebas de seguridad y evalúa vulnerabilidades.
- Desarrollador backend / frontend de soporte: apoya en la corrección de defectos detectados.
- Representante del negocio / Product Owner: valida los criterios de aceptación desde la perspectiva funcional del centro de salud.

Recursos técnicos (software, herramientas, equipos, navegadores, versiones):

- Postman/Newman y Swagger UI para pruebas de la API RESTful (auth, usuarios, pacientes, exámenes, documentos, auditoría).
- Jest y Supertest para pruebas unitarias y de integración del backend Express.

- OWASP ZAP para pruebas de seguridad (inyección SQL, XSS, CSRF, configuración de cabeceras y TLS).
- k6 o Apache JMeter para pruebas de carga y rendimiento (200 usuarios concurrentes).
- Lighthouse para métricas de rendimiento y accesibilidad del frontend React.
- Navegadores: últimas dos versiones de Chrome, Firefox, Safari y Edge; dispositivos desktop, tablet y móvil.

Entorno de prueba: se utilizará un ambiente QA aislado, con una base de datos PostgreSQL de prueba (independiente de producción), configuración TLS habilitada y datos de prueba representativos (pacientes, exámenes y documentos ficticios), replicando en la medida de lo posible la configuración del ambiente de producción.

3.5 Cronograma de ejecución

El ciclo de pruebas se ejecutará en un plazo estimado de 12 días hábiles, distribuidos en las siguientes etapas. Los tiempos son referenciales y podrán ajustarse según la disponibilidad del ambiente QA y la cantidad de defectos detectados durante la ejecución.

Etapa	Actividad	Duración estimada	Responsable(s)
1	Diseño de casos de prueba a partir del ERS y criterios de aceptación	Días 1–2	QA Lead, Analista de pruebas
2	Preparación del ambiente QA y datos de prueba (usuarios, pacientes, exámenes, documentos)	Día 3	Analista de pruebas, Desarrollador de soporte
3	Ejecución de pruebas funcionales y de integración (RF-1 a RF-5)	Días 4–5	Analista de pruebas
4	Ejecución de pruebas de seguridad (OWASP ZAP, control de acceso, inyección SQL, XSS, CSRF)	Días 6–7	Analista de seguridad
5	Ejecución de pruebas de rendimiento (k6 / JMeter, 200 usuarios concurrentes)	Día 8	Analista de pruebas
6	Ejecución de pruebas de usabilidad y accesibilidad con usuarios representativos	Día 9	QA Lead, Product Owner
7	Registro de defectos, retesting y pruebas de regresión	Días 10–11	Todo el equipo QA
8	Cierre del ciclo de pruebas y elaboración del informe de resultados	Día 12	QA Lead

4. Diseño de casos de prueba

A continuación, se detallan los casos de prueba representativos diseñados para cubrir los distintos tipos de requerimientos funcionales y no funcionales definidos en el ERS del sistema Cuidarte+.

ID	NOMBRE DEL CASO	REQUERIMIENTO ASOCIADO
CP-01	Autenticación exitosa con credenciales válidas	RF-1.1
DESCRIPCIÓN		
Verificar que un usuario registrado puede autenticarse en el sistema ingresando su nombre de usuario y contraseña correctos.		
PRECONDICIONES		
El usuario existe en la base de datos con su contraseña almacenada mediante hashing (bcrypt). El backend y la base de datos se encuentran disponibles.		
PASOS		
1. Acceder a la pantalla de Login. 2. Ingresar un nombre de usuario válido. 3. Ingresar la contraseña correcta. 4. Presionar el botón "Ingresar".		
DATOS DE ENTRADA / PRUEBA		
Usuario: jperez / Contraseña: Duoc2026!Segura		
RESULTADO ESPERADO		
El sistema valida las credenciales, genera un token de sesión (JWT) y redirige al Dashboard correspondiente según el rol del usuario.		
CRITERIO DE ACEPTACIÓN		
Se recibe un token JWT válido; la redirección corresponde al rol asignado; no se expone información sensible en la respuesta del servidor.		
TIPO DE PRUEBA		
Funcional		

ID	NOMBRE DEL CASO	REQUERIMIENTO ASOCIADO
CP-02	Registro de nuevo usuario con rol paciente por defecto	RF-2.1
DESCRIPCIÓN		
Verificar que un visitante puede registrarse ingresando usuario, correo y contraseña, quedando habilitado con el rol "paciente" de forma automática.		
PRECONDICIONES		
El correo electrónico ingresado no se encuentra previamente registrado en el sistema.		
PASOS		
1. Acceder al formulario de Registro. 2. Ingresar nombre de usuario, correo electrónico y contraseña. 3. Confirmar el registro.		
DATOS DE ENTRADA / PRUEBA		
Correo: paciente.prueba@correo.cl / Contraseña: Cuidarte+2026#		
RESULTADO ESPERADO		
La cuenta se crea correctamente con rol "paciente" y el usuario puede iniciar sesión de inmediato.		
CRITERIO DE ACEPTACIÓN		
El sistema valida formato de correo y política de contraseña (mínimo 12 caracteres, mayúscula, minúscula, número y símbolo); el rol asignado por defecto es "paciente".		
TIPO DE PRUEBA		
Funcional		

ID	NOMBRE DEL CASO	REQUERIMIENTO ASOCIADO
CP-03	Carga de documento médico en formato permitido	RF-4.3 / RF-4.4
DESCRIPCIÓN		
Verificar que un usuario médico puede adjuntar un documento a un examen médico en uno de los formatos permitidos por el sistema.		
PRECONDICIONES		
Usuario con rol médico autenticado; paciente y examen médico previamente registrados.		
PASOS		
1. Acceder a Gestión de Exámenes Médicos. 2. Seleccionar el examen del paciente. 3. Adjuntar un documento en formato PDF. 4. Guardar los cambios.		
DATOS DE ENTRADA / PRUEBA		
Archivo: examen_sangre.pdf (2 MB)		
RESULTADO ESPERADO		
El documento se almacena en el storage interno y queda correctamente referenciado en la base de datos, quedando disponible para su visualización y descarga.		
CRITERIO DE ACEPTACIÓN		
La subida se completa en un tiempo no mayor a 10 segundos; el formato es validado (solo se aceptan PDF, DOC, PPT, JPG, PNG); la referencia en base de datos es correcta.		
TIPO DE PRUEBA		
Funcional / Integración		

ID	NOMBRE DEL CASO	REQUERIMIENTO ASOCIADO
CP-04	Control de acceso: paciente intenta visualizar examen de otro paciente	RB-1 / NFR-SEG-4
DESCRIPCIÓN		
Verificar que un usuario con rol paciente no puede acceder a la información clínica de un paciente distinto al propio.		
PRECONDICIONES		
Existen dos pacientes registrados (A y B), cada uno con exámenes propios. El paciente A se encuentra autenticado en el sistema.		
PASOS		
1. Autenticarse como paciente A. 2. Intentar acceder, mediante manipulación del identificador del recurso en la solicitud, al examen médico perteneciente al paciente B.		
DATOS DE ENTRADA / PRUEBA		
Identificador del examen médico del paciente B (ID/UUID ajeno)		
RESULTADO ESPERADO		
El sistema deniega el acceso y responde con un error de autorización (HTTP 403), sin exponer datos del paciente B.		
CRITERIO DE ACEPTACIÓN		
El acceso es denegado en el 100% de los intentos; el intento queda registrado en el módulo de auditoría (RF-5.1).		
TIPO DE PRUEBA		
Seguridad		

ID	NOMBRE DEL CASO	REQUERIMIENTO ASOCIADO
CP-05	Resistencia a inyección SQL en el formulario de autenticación	NFR-SEG-5
DESCRIPCIÓN		
Verificar que el sistema valida y sanea correctamente las entradas del formulario de login ante intentos de inyección SQL.		
PRECONDICIONES		
El formulario de Login se encuentra disponible y accesible.		
PASOS		
1. Ingresar en el campo de usuario una cadena con sintaxis de inyección SQL. 2. Ingresar una contraseña cualquiera. 3. Presionar "Ingresar".		
DATOS DE ENTRADA / PRUEBA		
Usuario: ' OR '1'='1 / Contraseña: cualquiera		
RESULTADO ESPERADO		
El sistema rechaza la autenticación, no ejecuta la sentencia maliciosa y retorna un mensaje de error genérico.		
CRITERIO DE ACEPTACIÓN		
No se produce bypass de autenticación; no se exponen mensajes de error con detalles de la consulta SQL ni trazas internas del servidor.		
TIPO DE PRUEBA		
Seguridad		

ID	NOMBRE DEL CASO	REQUERIMIENTO ASOCIADO
CP-06	Tiempo de respuesta de operaciones CRUD bajo carga normal	NFR-PERF-1 / NFR-PERF-3
DESCRIPCIÓN		
Verificar que la operación de creación de un examen médico responde dentro del umbral establecido con 200 usuarios concurrentes.		
PRECONDICIONES		
Ambiente QA configurado con datos de prueba y herramienta de carga (k6 o JMeter) configurada.		
PASOS		
1. Ejecutar un script de carga con 200 usuarios concurrentes creando exámenes médicos durante 10 minutos. 2. Medir el tiempo de respuesta promedio y el percentil 95.		
DATOS DE ENTRADA / PRUEBA		
Carga simulada: 200 usuarios concurrentes, duración 10 minutos		
RESULTADO ESPERADO		
El 95% de las solicitudes se responde en un tiempo inferior a 300 ms, sin errores de servidor (5xx).		
CRITERIO DE ACEPTACIÓN		
Tiempo de respuesta promedio inferior a 300 ms bajo carga normal; ausencia de errores 5xx durante la ejecución de la prueba.		
TIPO DE PRUEBA		
Rendimiento		

ID	NOMBRE DEL CASO	REQUERIMIENTO ASOCIADO
CP-07	Accesibilidad y usabilidad del registro para adultos mayores	NFR-USAB-1 / NFR-USAB-2
DESCRIPCIÓN		
Verificar que el formulario de registro cumple con criterios de accesibilidad y usabilidad orientados a usuarios adultos mayores.		
PRECONDICIONES		
Se dispone de 5 usuarios representativos (adultos mayores) para la prueba de usabilidad, en distintos dispositivos (desktop, tablet, móvil).		
PASOS		
1. Solicitar a cada usuario completar el flujo de registro sin asistencia. 2. Registrar dificultades, tiempos y errores observados. 3. Verificar contraste, tamaño de fuente (mínimo 12px), etiquetas ARIA y navegación por teclado.		
DATOS DE ENTRADA / PRUEBA		
No aplica (prueba cualitativa con usuarios representativos)		
RESULTADO ESPERADO		
Los usuarios completan el registro sin bloqueos mayores; los controles cumplen el tamaño mínimo definido para pantallas táctiles.		
CRITERIO DE ACEPTACIÓN		
Al menos 4 de 5 usuarios completan el flujo sin asistencia; se cumplen los criterios básicos de accesibilidad definidos; los mensajes de error son comprensibles.		
TIPO DE PRUEBA		
Usabilidad / Accesibilidad		

5. Conclusión

El diseño del presente plan de pruebas permitió establecer una estrategia integral para validar la calidad del sistema Cuidarte+, abarcando no solo la verificación funcional de los módulos de autenticación, gestión de pacientes, exámenes médicos, documentos clínicos y auditoría, sino también los atributos no funcionales de seguridad, rendimiento, usabilidad, disponibilidad y compatibilidad definidos en el ERS.

La incorporación de casos de prueba orientados específicamente a seguridad (control de acceso por rol y resistencia a inyección SQL) resulta especialmente relevante considerando que Cuidarte+ administra datos clínicos y personales sensibles, cuyo tratamiento indebido podría vulnerar tanto la confidencialidad de los pacientes como la normativa legal vigente en Chile. Asimismo, la inclusión de pruebas de usabilidad enfocadas en adultos mayores responde directamente al perfil de usuario final declarado en el alcance del proyecto, evidenciando que la calidad de un sistema no se limita a su correcto funcionamiento técnico, sino también a su accesibilidad y facilidad de uso para todos los perfiles de usuario.

En conjunto, la estrategia, los tipos de prueba y los casos diseñados en este informe entregan una base sólida y trazable para ejecutar el plan de pruebas en un ambiente QA, permitiendo detectar oportunamente defectos funcionales, brechas de seguridad y desviaciones respecto de los estándares de calidad y cumplimiento normativo exigidos, antes de que el sistema sea puesto en producción.

6. Referencias

Biblioteca del Congreso Nacional de Chile. (1999). Ley N.º 19.628 sobre protección de la vida privada. https://www.bcn.cl/leychile/navegar?idNorma=141599

Biblioteca del Congreso Nacional de Chile. (2012). Ley N.º 20.584 que regula los derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud. https://www.bcn.cl/leychile/navegar?idNorma=1039348

International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security management systems — Requirements. https://www.iso.org/standard/27001.html

International Software Testing Qualifications Board. (2023). Foundation level syllabus. https://www.istqb.org

OWASP Foundation. (2021). OWASP Top Ten. https://owasp.org/www-project-top-ten/

World Wide Web Consortium. (2018). Web Content Accessibility Guidelines (WCAG) 2.1. https://www.w3.org/TR/WCAG21/

DuocUC, Escuela de Informática y Telecomunicaciones. (2026). Sistema de exámenes médicos Cuidarte+: Especificación de requerimientos de software EP1_ISY1102_Estudiante_ERS_B.pdf

CreaLab Spa.

DuocUC, Subdirección de Diseño Curricular e Instruccional. (2025). Evaluación Parcial N.º 1: Diseñando un plan de pruebas seguro, legal y normativo — Instrucciones y pauta de evaluación EP1_ISY1102_Estudiante_Formato_Informe.docx

.